Seguridad, Rendimiento y Disponibilidad de Servicios e Infraestructuras

Ana I. González Acuña

Grado en Ingeniería Informática



2024/25

SRDSI

1. Introducción a la seguridad informática
2. Seguridad en la comunicación
3. Seguridad en los servicios
4. Seguridad Operacional



Tema 1: Introducción a la seguridad informática



1 Introducción a la seguridad informática
1.1 Conceptos básicos de seguridad informática
1.2 Introducción a la criptografía
1.3 Características comunicación segura
1.4 Gestión de claves.



1 Introducción a la seguridad informática
1.1 Conceptos básicos de seguridad informática
1.2 Introducción a la criptografía
1.3 Características comunicación segura
- Confidencialidad
- No repudio e Integridad
- Firma digital
- Autenticación

1.4 Gestión de claves.



Características de una comunicación segura

- Confidencialidad
  Proporciona protección para evitar que la información, almacenada o que circule por una red, sea revelada, accidental o deliberadamente, a una entidad (usuario o proceso) no autorizada.
- Integridad
  Garantiza que la información no ha sido alterada, duplicada o destruida de una manera no autorizada o debido a un error.
- No repudio
  Evitar que cualquier entidad que participó en una comunicación niegue haber tomado parte en ella.
- Autenticación
  Permite verificar la identidad de las entidades participes y el origen de la información.



Protocolos criptográficos

- **Algoritmo criptográfico** transforma los datos de entrada en datos de salida mediante técnicas criptográficas
  Su solo uso no es suficiente si no está integrado en un contexto semántico.
- **Protocolo criptográfico** es un procedimiento compuesto por una serie de pasos de procesamiento y de intercambios de mensajes entre entidades, cuyo propósito es lograr un objetivo de seguridad específico.



Confidencialidad

Protocolo básico:

- [Generar/obtener clave]
- Cifrar el mensaje para obtener un criptograma (usando técnicas de criptografía)
- Enviar/almacenar criptograma
- Descifrar criptograma

Clave	**A** (cifra)	$\Longrightarrow$	**B** (descifra)
$\mathtt{Sim}_{AB}$	$\mathtt{C} = \mathtt{Sim}_{AB}(\mathtt{M})$	$\xrightarrow{C}$	$\mathtt{M} = \mathtt{Sim}_{AB}(\mathtt{C})$
$\mathtt{Pub}_{B}$	$\mathtt{C} = \mathtt{Pub}_{B}(\mathtt{M})$	$\xrightarrow{C}$	$\mathtt{M} = \mathtt{Priv}_{B}(\mathtt{C})$



ACTIVIDAD

GnuPG (GNU Privacy Guard): Confidencialidad

- [Instalar GnuPG]
- Comprobar qué algoritmos tiene implementados el sistema
  gpg --version



ACTIVIDAD

GnuPG (GNU Privacy Guard): Confidencialidad

- [Instalar GnuPG]
- Comprobar qué algoritmos tiene implementados el sistema
  gpg --version
- Cifrar con clave simétrica ¿Descifrar?
  gpg --symmetric --cipher-algo algoritmo [-a -v] file.txt



ACTIVIDAD

GnuPG (GNU Privacy Guard): Confidencialidad

- [Instalar GnuPG]
- Comprobar qué algoritmos tiene implementados el sistema
  gpg --version
- Cifrar con clave simétrica ¿Descifrar?
  gpg --symmetric --cipher-algo algoritmo [-a -v] file.txt
- Generar claves asimétricas
  gpg {--gen-key , --full-generate-key [--expert] }
- Listar claves
  gpg {-k , -K}
- Cifrar con clave pública ¿Descifrar?
  gpg --recipient name --encrypt file.txt



ACTIVIDAD

GnuPG (GNU Privacy Guard): Confidencialidad

- [Instalar GnuPG]
- Comprobar qué algoritmos tiene implementados el sistema
  gpg --version
- Cifrar con clave simétrica ¿Descifrar?
  gpg --symmetric --cipher-algo algoritmo [-a -v] file.txt
- Generar claves asimétricas
  gpg {--gen-key , --full-generate-key [--expert] }
- Listar claves
  gpg {-k , -K}
- Cifrar con clave pública ¿Descifrar?
  gpg --recipient name --encrypt file.txt
- Backup clave privada ¿Clave pública?
  gpg --output privada.gpg [--armor] --export-secret-key claveID



Integridad

Protocolo básico:

- Calcular el valor resumen del mensaje
- Enviar/almacenar resumen (+ mensaje)
- Verificar que el mensaje no ha sido modificado

$$A \quad \Longrightarrow \quad B$$

$$C = [H(M), M] \quad \xrightarrow{C} \quad ¿\ H(M) = H'(M)\ ?$$



ACTIVIDAD

Comprobar integridad

- Crear resumen:
  `md5sum archivo.txt > archivo.md5`
  `gpg --print-mds` *`archivo.txt`*
- ¿ Verificar integridad?



No repudio

- No repudio en origen: El emisor no puede negar que envió el mensaje porque el receptor tiene pruebas del envío. En este caso, la prueba la crea el propio emisor y la recibe el receptor
- No repudio en destino: El receptor no puede negar que recibió el mensaje porque el emisor tiene pruebas de la recepción. En este caso, la prueba irrefutable la crea el receptor (por ejemplo: acuse de recibo firmado y datado) y la recibe el emisor.

Se garantiza utilizando firmas digitales.



Firma digital

- Permite
  - Al receptor de un mensaje:
    - ★ validar la autenticidad del origen de la información (autenticación)
    - ★ verificar que la información no ha sido modificada (integridad)
  - El emisor del mensaje firmado no puede argumentar que no lo hizo (no repudio)
- Mismo propósito que la firma manuscrita.
- Solo posible con criptografía asimétrica.
- Protocolos de firma digital: DSS Digital Signature Standard (RSA, ~~DSA~~, ECDSA, EdDSA...)

Cryptobook, firmas digitales

NIST FIPS 186-5



- Protocolos de firma digital siempre comprenden dos procesos: **generación** y **verificación** de la firma
- Protocolo básico de firma digital:

A (Generación) $\Longrightarrow$ B (Verificación)

$\texttt{C} = \texttt{Priv}_{\texttt{A}}(\texttt{M}) \xrightarrow{\texttt{C}} \texttt{M} = \texttt{Pub}_{\texttt{A}}(\texttt{C})$



- Protocolos de firma digital siempre comprenden dos procesos: **generación** y **verificación** de la firma
- Protocolo básico de firma digital:

A (Generación) $\Longrightarrow$ B (Verificación)

~~$C = Priv_A(M)$~~ $\xrightarrow{C}$ ~~$M = Pub_A(C)$~~

$C = [M, Priv_A(M)]$ $\xrightarrow{C}$ ¿ $M = Pub_A(Priv_A(M))$?



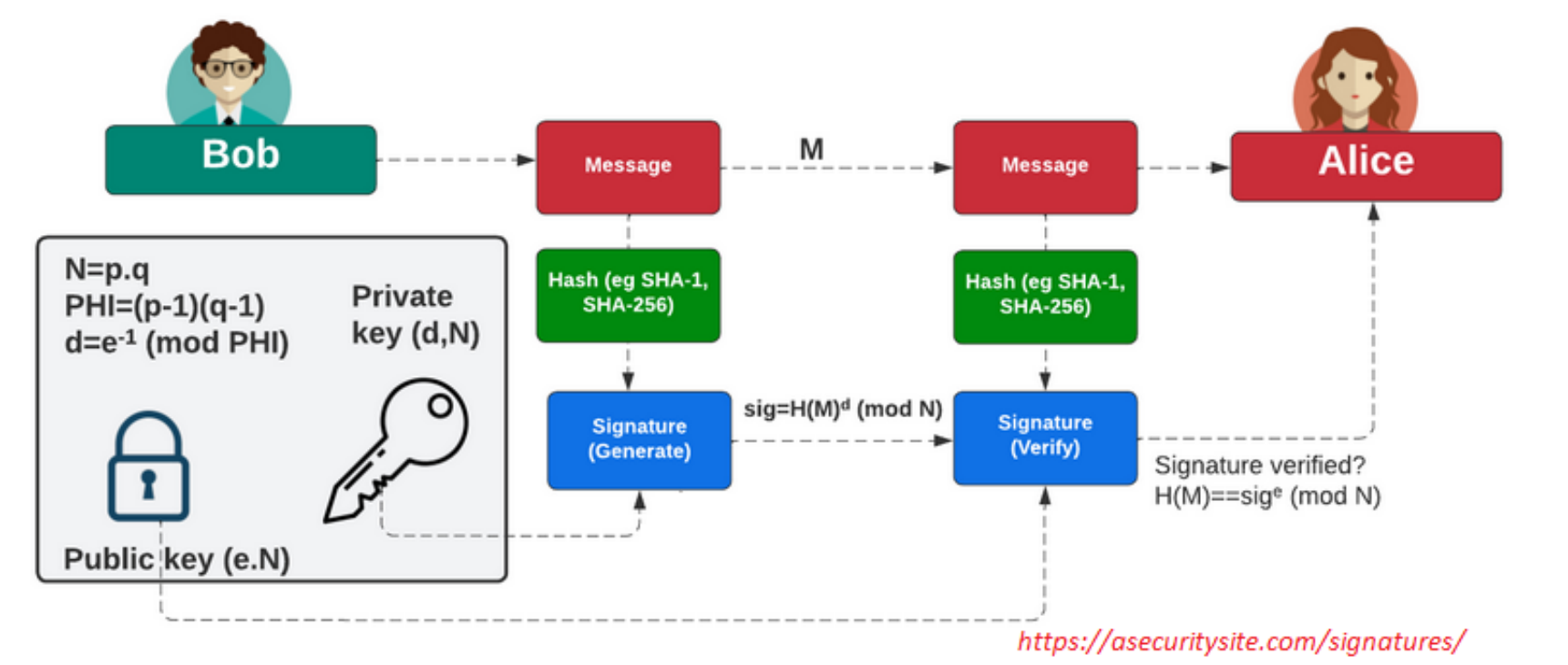
- Protocolos de firma digital siempre comprenden dos procesos: **generación** y **verificación** de la firma
- Protocolo básico de firma digital:

A (Generación)	$\Longrightarrow$	B (Verificación)
~~$C = Priv_A(M)$~~	$\xrightarrow{C}$	~~$M = Pub_A(C)$~~
~~$C = [M, Priv_A(M)]$~~	$\xrightarrow{C}$	~~¿ $M = Pub_A(Priv_A(M))$?~~
$C = [M, Priv_A(H(M))]$	$\xrightarrow{C}$	¿ $H(M) = Pub_A(Priv_A(H(M)))$?

Requisito: validación de la clave pública Pub_A



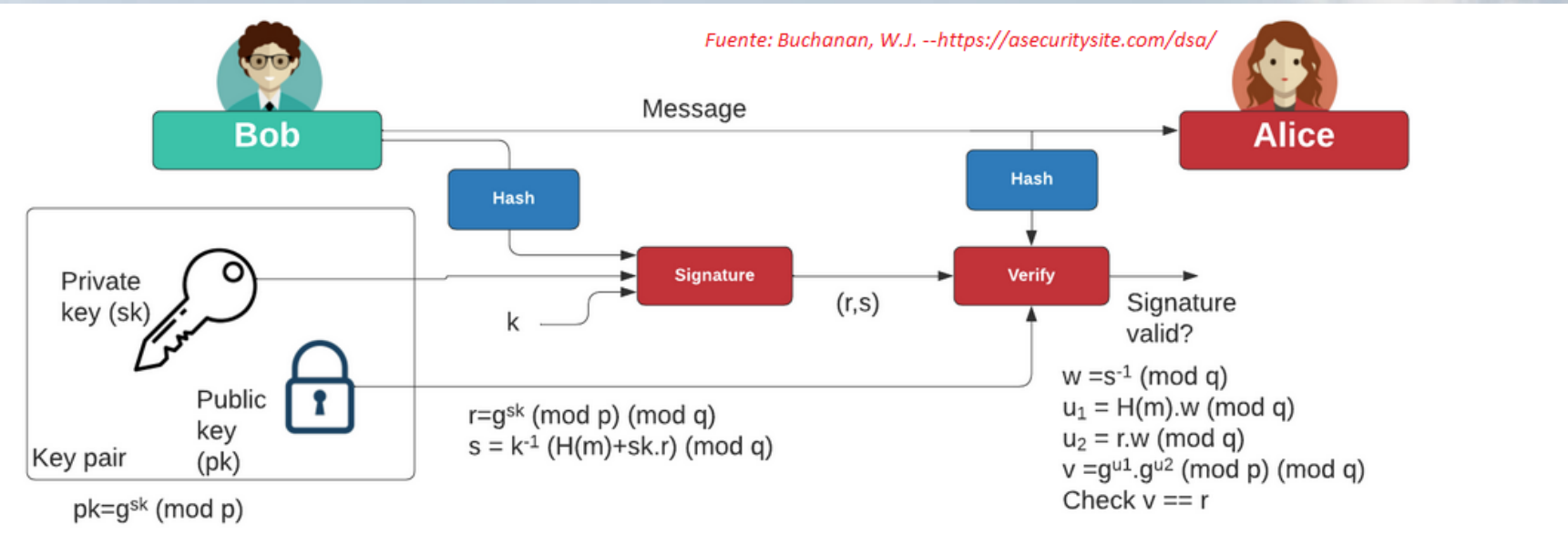
RSA-based Signature (RFC 8017)



["*Digital Signatures with RSA and Other Public-Key Cryptosystems*" Dorothy E. Denning 1984]



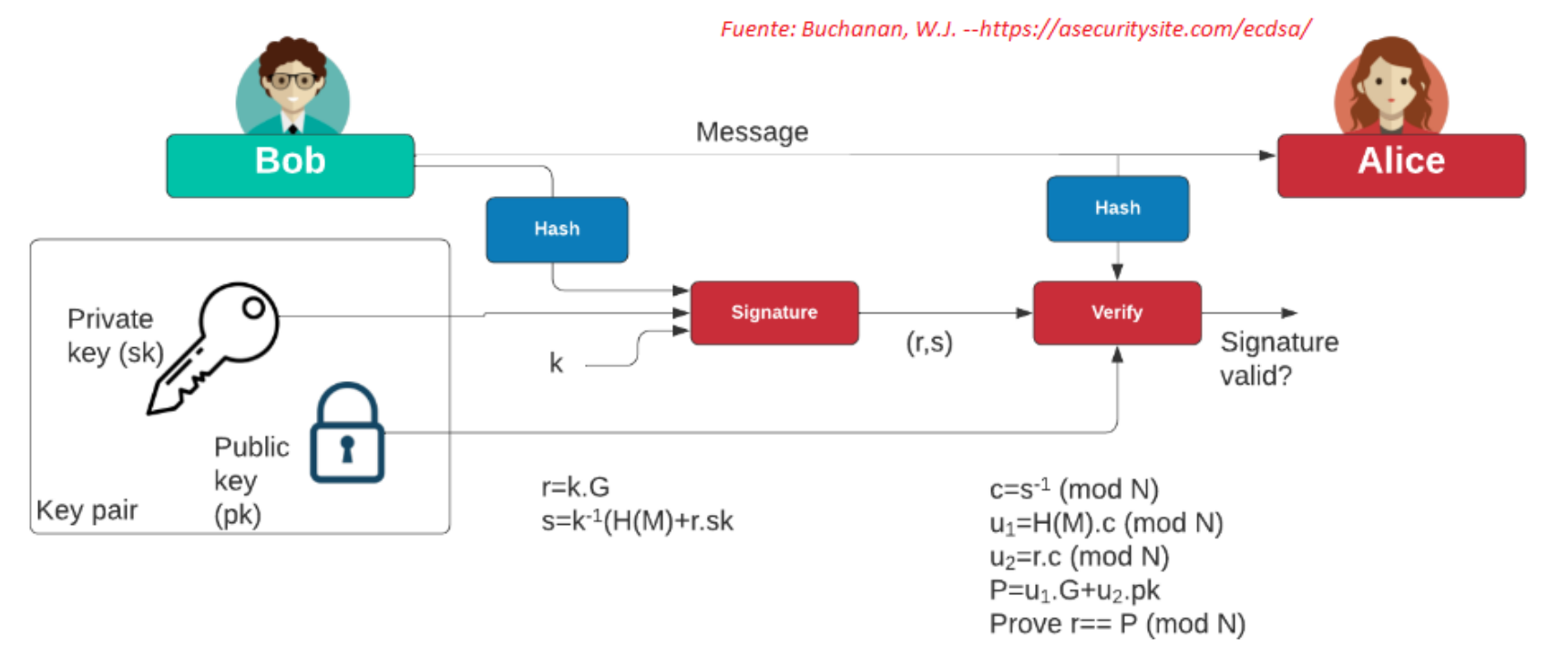
DSA (Digital Signature Algorithm)



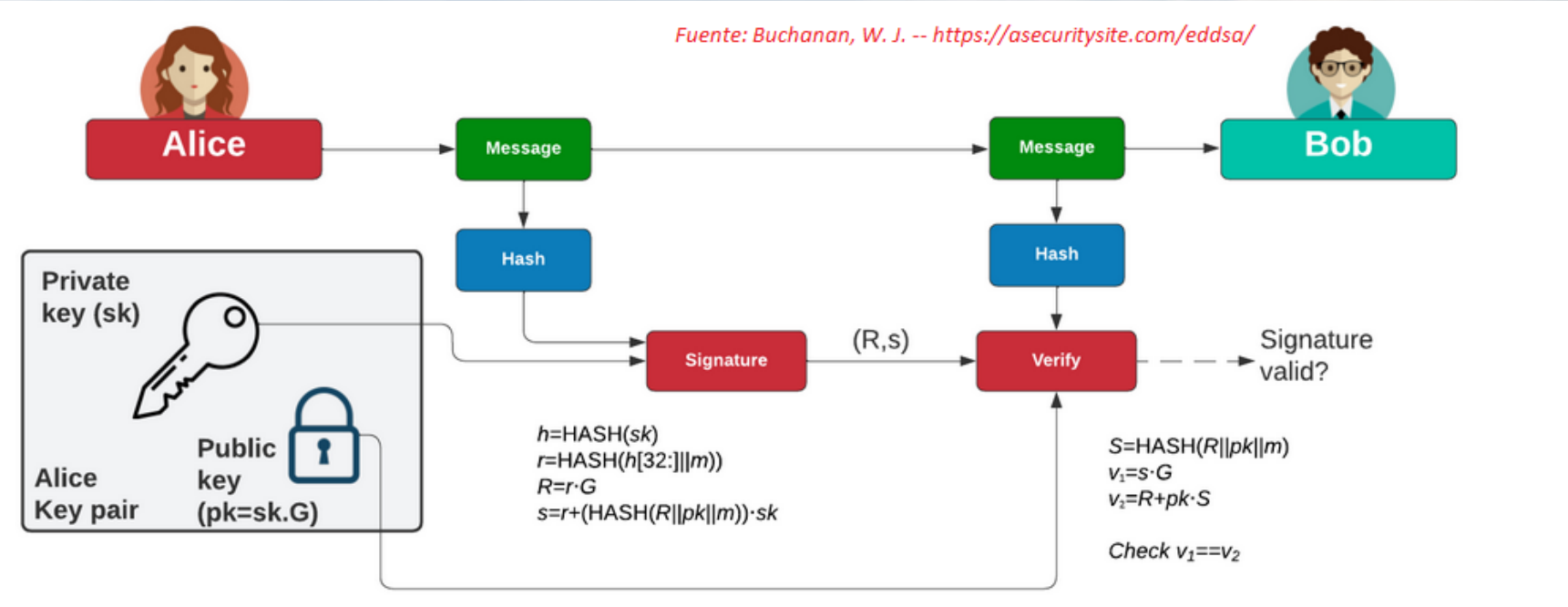
DSA Signature **OBSOLETED** BY NIST-FIPS- 186-5 (En23). Only to verify previously digital signatures.

*"Note that the algorithms in this standard are not expected to provide resistance to attacks from a large-scale **quantum computer.** Digital signature algorithms that will provide security from quantum computers will be specified in future NIST publications"*

ECDSA (Elliptic Curve Digital Signature Algorithm (RFC 6979))



EdDSA (Edwards Curve Digital Signature Algorithm (RFC 8032))



ACTIVIDAD

GnuPG (GNU Privacy Guard): Firma Digital

Diversas opciones para firmar documentos:

- mensaje + firma digital en un fichero
  `gpg --clearsign` *`file.txt`*



ACTIVIDAD

GnuPG (GNU Privacy Guard): Firma Digital

Diversas opciones para firmar documentos:

- mensaje + firma digital en un fichero
  `gpg --clearsign` *`file.txt`*
- solo firma digital en un fichero distinto
  `gpg --detach-sign -a` *`file.txt`*



ACTIVIDAD

GnuPG (GNU Privacy Guard): Firma Digital

Diversas opciones para firmar documentos:

- mensaje + firma digital en un fichero
  `gpg --clearsign` *`file.txt`*
- solo firma digital en un fichero distinto
  `gpg --detach-sign -a` *`file.txt`*
- mensaje cifrado + firma digital en un fichero
  `gpg --sign --encrypt` *`file.txt`*



ACTIVIDAD

GnuPG (GNU Privacy Guard): Firma Digital

Diversas opciones para firmar documentos:

- mensaje + firma digital en un fichero
  `gpg --clearsign` *`file.txt`*
- solo firma digital en un fichero distinto
  `gpg --detach-sign -a` *`file.txt`*
- mensaje cifrado + firma digital en un fichero
  `gpg --sign --encrypt` *`file.txt`*

- ¿Verificar firma digital?



Ejercicios

- Descifrar con criptografía simétrica. Anotar tiempo.
- Descifrar con criptografía asimétrica. Anotar tiempo y comparar con anterior.
- Comparar tamaño de los criptogramas obtenidos con criptografía simétrica vs asimétrica.
- Comparar tamaño de los criptogramas obtenidos con diferentes tamaño de clave.
- Exportar una clave pública a un fichero.
- Crear dos ficheros que solo difieran en un carácter y comparar sus resúmenes .
- Descargar un ejecutable de una página web (autenticada) y cotejar con su "firma" de verificación.
- Editar un fichero cifrado / firma digital , modificar un carácter, comprobar que se detecta la modificación.



Autenticación

Verificar la identidad de una persona/entidad en base a uno o varios factores:

- Lo que sabe (usuario/password, PIN)
- Lo que tiene (tarjeta, token, móvil)
- Quién es/hace (identificadores biométricos: huella digital, voz, firma)
- Dónde está: *source* IP

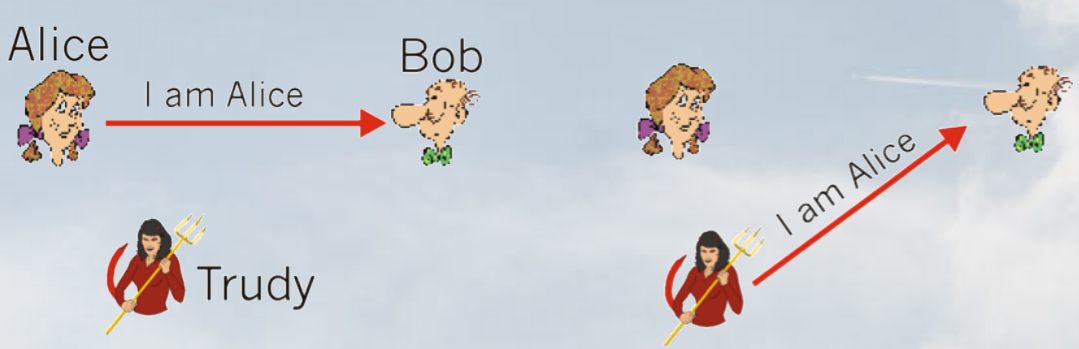
Protocolos desafío-respuesta (*challenge–response authentication*):

- Usuario/password : *password* no viaja en claro, forma parte de un cálculo junto con el desafío
- Criptográficos: identificación de la entidad por su clave de cifrado.

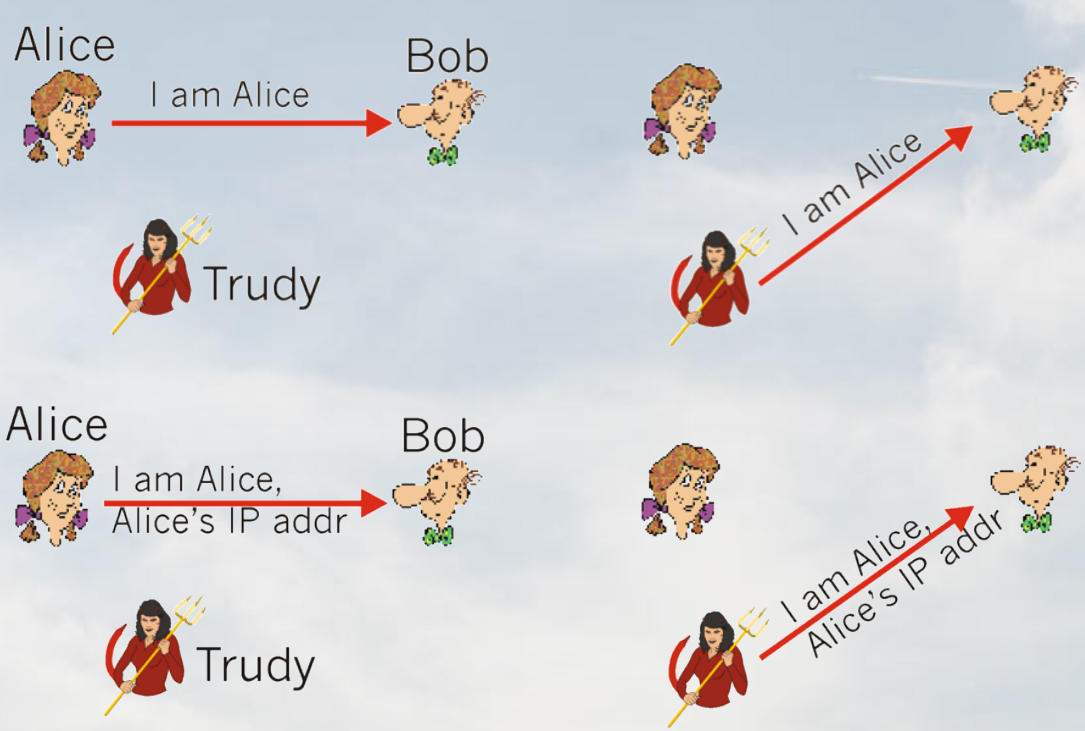
NIST SP 800-63B Digital Identity Guidelines



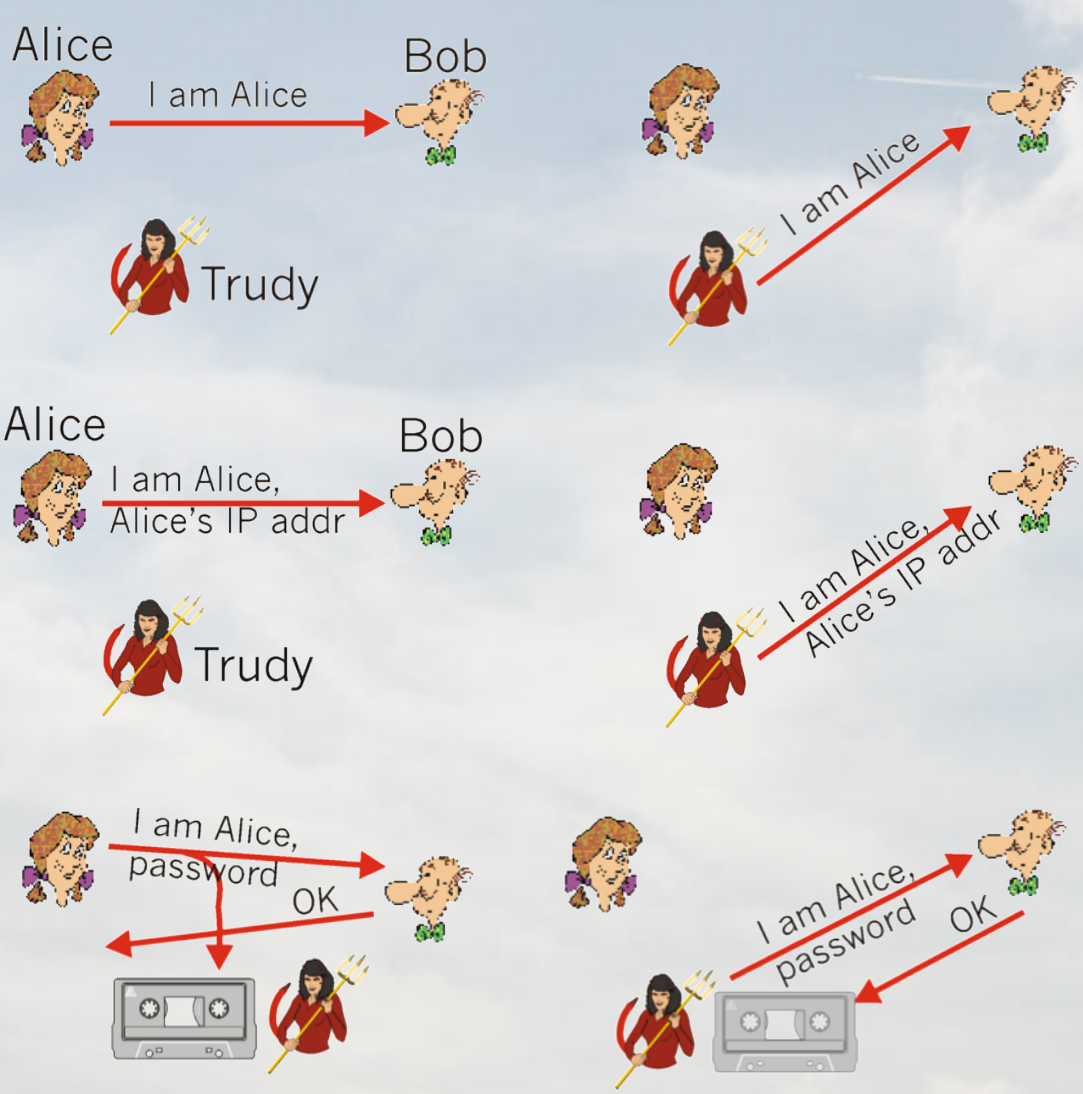
Protocolos de autenticación (fallidos)



Protocolos de autenticación (fallidos)

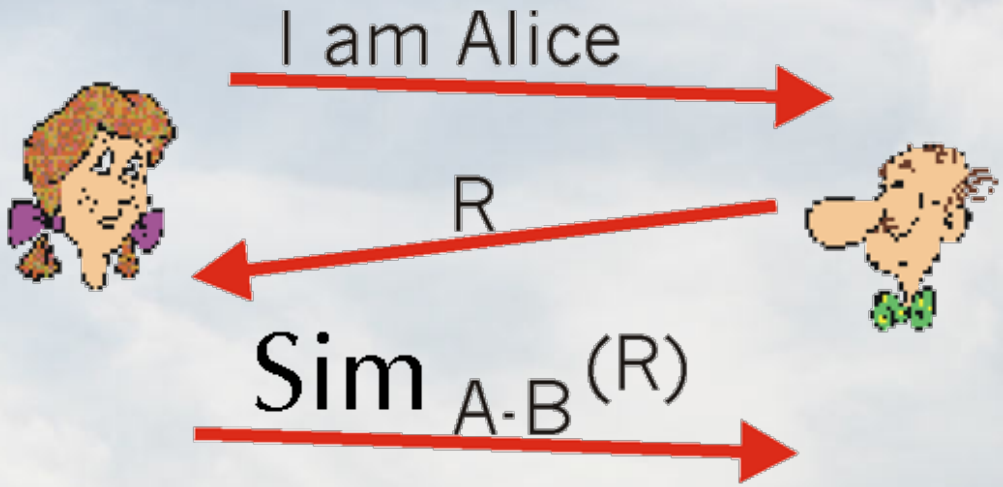


Protocolos de autenticación (fallidos)



fuente: instructors.pearsonhighered.com

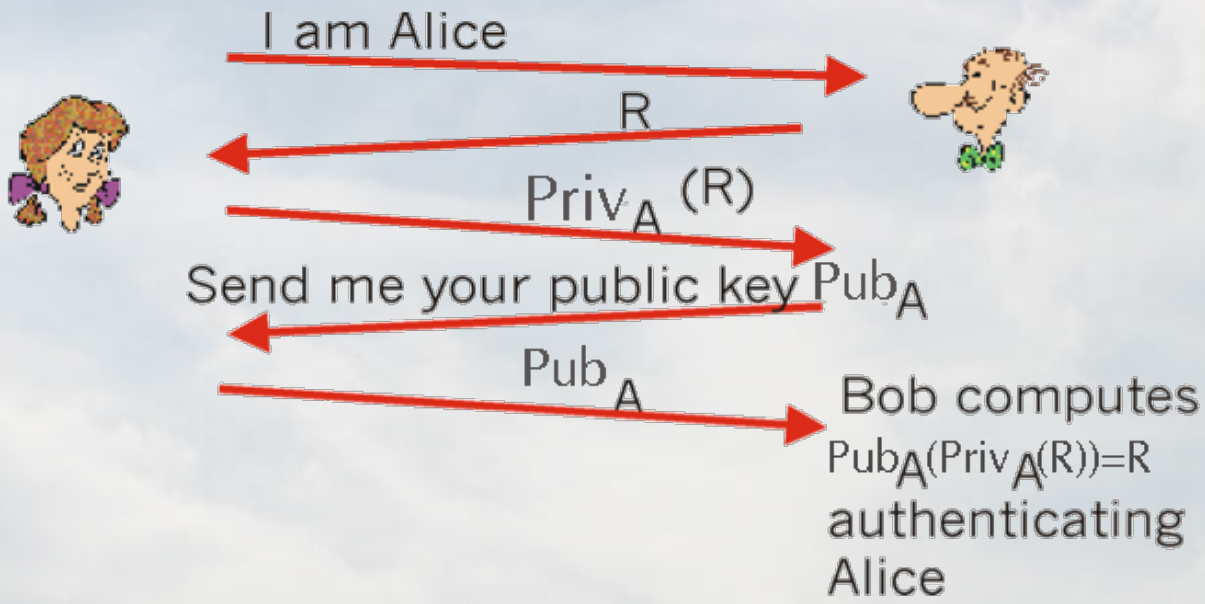
Autenticación basada en criptografía simétrica



fuente: instructors.pearsonhighered.com

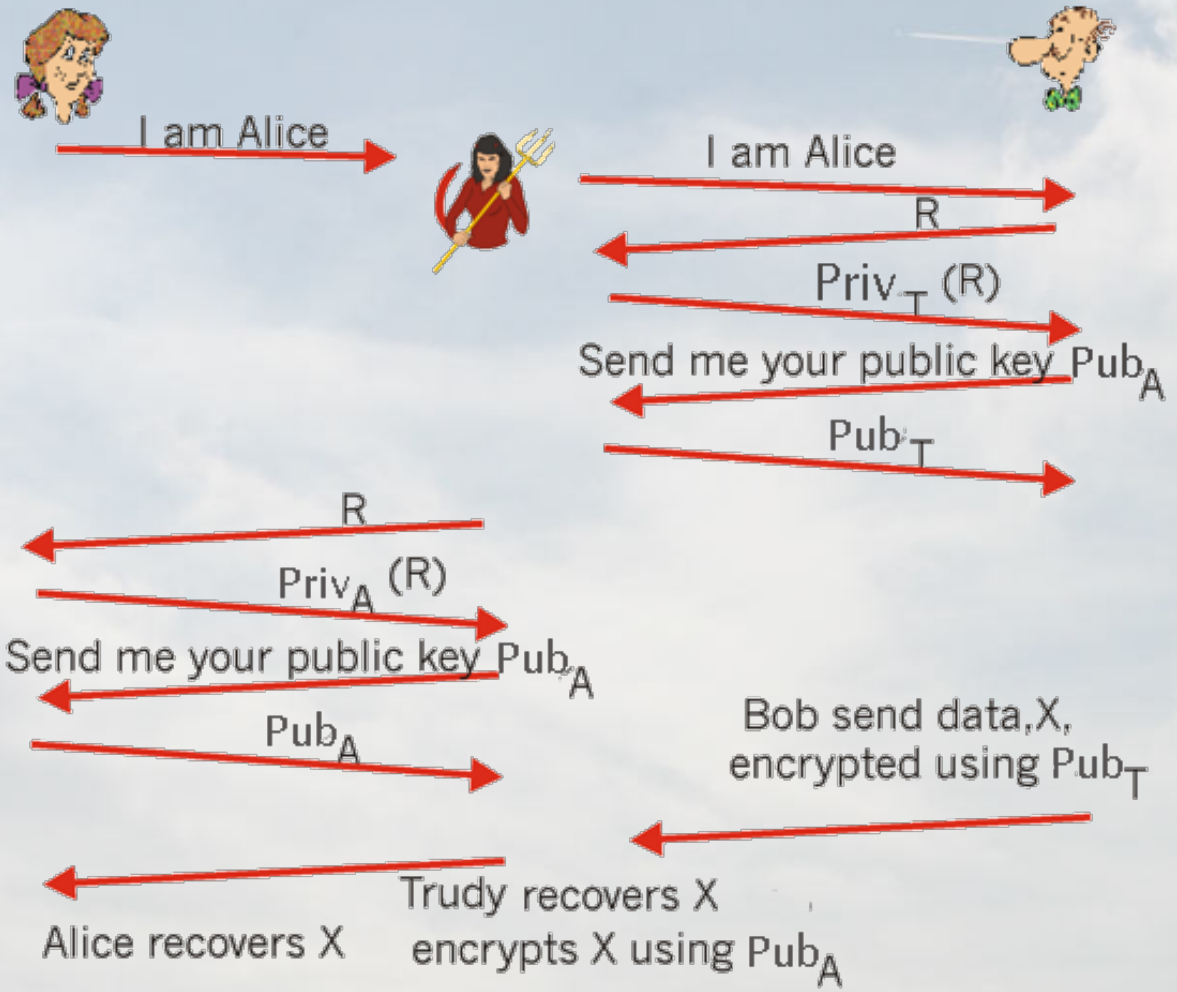
nonce (reto, token): un número que un protocolo sólo utiliza una única vez.

Autenticación basada en criptografía asimétrica



fuente: instructors.pearsonhighered.com

Man in the middle attack (MiM)



fuente: instructors.pearsonhighered.com